INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY (ICDFA)

Governance, Compliance, and Risk (GCR)
Course 3: GRC103 - Risk Assessment & Management Techniques

Week 1 Lab-Based Assignment:

Technical Scanning To GRC Analysis

Student Name: Chioma Chinonyelum Onyekelu

Student ID: 2025/GCR/12696

Instructor Name: Mr. Aminu Idris, AMCPN

Date: 11/04/2026

Lab Objectives:

By completing this lab, I successfully achieved the following:

- **Executed Technical Scans:** Utilized Nmap, Nikto, and Nuclei to systematically discover services and identify vulnerabilities within the target environment.
- **Analyzed Technical Output:** Interpreted complex scan data to isolate specific service versions and critical security misconfigurations.
- **Conducted Risk Triage:** Mapped identified vulnerabilities to standardized risk levels based on their potential business impact.
- **Aligned Findings with Frameworks:** Connected technical results to industry standards including **CIS Controls**, **NIST CSF**, and **NIST 800-53**.
- **Drafted Executive Reports:** Communicated high-level technical risks to management using concise, business-focused language.
- **Quantified Financial Risk:** Calculated **Single Loss Expectancy (SLE)** and **Annualized Loss Expectancy (ALE)** to determine potential financial exposure.
- **Developed Risk Treatment Plans:** Formulated strategic response plans to **Mitigate, Transfer, Accept, or Avoid** identified risks.
- **Mapped Security Controls:** Aligned specific vulnerabilities with relevant administrative and technical controls from the **NIST 800-53** catalog.
- **Integrated Business Impact Analysis (BIA):** Evaluated the implications of service failures on core business processes using **RTO** and **RPO** metrics.

Executive Summary

This lab demonstrates the practical implementation of a full-spectrum vulnerability management and risk assessment lifecycle, transitioning from technical service discovery to business-focused risk quantification and governance. The objective was to evaluate the security posture of the 'Metasploitable' development server and translate technical exposure into actionable intelligence aligned with **NIST SP 800-53**, **NIST CSF**, and **CIS Controls**.

The exercise began with foundational **Information Gathering and Service Discovery** using **Nmap**. By performing comprehensive version detection and script scanning, a broad attack surface was identified, characterized by numerous open ports and insecure legacy protocols such as **FTP (21)**, **Telnet (23)**, and **SMB (445)**. These findings highlighted a fundamental lack of hardening and a violation of the **Principle of Least Functionality**, directly contradicting **CIS Control 9** and **NIST CSF PR.IP-1**.

Building on this discovery, **Vulnerability Identification** was performed using automated assessment tools including **Nikto** and **Nuclei**. This phase revealed critical security failures, most notably a documented backdoor in the **vsFTPd service (CVE-2011-2523)**, default credentials in the **PostgreSQL database**, and remote code execution (RCE) vulnerabilities in **PHP**. The integration of **xsltproc** to generate HTML-based reporting ensured that these technical findings were documented in a structured, auditable format suitable for stakeholders.

The core GRC component of the lab involved a shift from technical scanning to **Quantitative Risk Analysis**. By calculating the **Annualized Loss Expectancy (ALE)** for high-risk assets, it was determined that the organization faces a projected financial exposure of **$359,500** annually. Specifically, the risk of full system compromise via the FTP backdoor and database exfiltration accounted for over **$200,000** of the total exposure. This quantitative approach provided the necessary business context to justify a **1,266% Return on Security Investment (ROSI)** for the proposed remediation efforts.

Further, a **Business Impact Analysis (BIA)** and **Risk Treatment Strategy** were developed to align security operations with business continuity objectives. Recovery Time Objectives (RTO) and Recovery Point Objectives (RPO) were established to prioritize the restoration of core IT operations and customer data management. A strategic mapping to **NIST 800-53 controls**, including **SI-2 (Flaw Remediation)** and **CM-7 (Least Functionality)**, was implemented to move the system toward a compliant, hardened state.

Overall, the lab successfully demonstrates how layered vulnerability assessments, financial risk modeling, and standard-based control mapping strengthen an organization's **Security Governance framework**. By transforming raw scan data into measurable risk metrics, this exercise enables data-driven decision-making, improves response efficiency, and ensures rigorous alignment with modern compliance and risk management objectives.

Phase 1: Information Gathering & Service Discovery

In this part, I identified open ports and services on the target system to determine the attack surface.

Tasks:

A. Create a working directory:
B. Perform an initial Nmap scan: Run a comprehensive scan to identify services, versions, and default scripts.
C. Generate an HTML report: Use xsltproc to convert the XML output into a readable HTML format for reporting.

<u>Answers</u>

A. Creating a working directory and Performing an initial Nmap scan (Screenshot)

```
┌──(icdfa㉿icdfa)-[~]
└─$ cd /home/icdfa/grc-lab-week1/task1/

┌──(icdfa㉿icdfa)-[~/grc-lab-week1/task1]
└─$ ls
initial_scan.gnmap  initial_scan.nmap  initial_scan.xml

┌──(icdfa㉿icdfa)-[~/grc-lab-week1/task1]
└─$ cat initial_scan.nmap
# Nmap 7.95 scan initiated Thu Apr  9 16:00:26 2026 as: /usr/lib/nmap/nmap --privileged -sV -sC -oA initial_scan 192.168.153.133
Nmap scan report for 192.168.153.133
Host is up (0.00049s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to 192.168.153.132
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      vsFTPd 2.3.4 - secure, fast, stable
|_End of status
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
|_ssl-date: 2026-04-09T15:00:49+00:00; 0s from scanner time.
|_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
| sslv2:
|   SSLv2 supported
|   ciphers:
|     SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
```

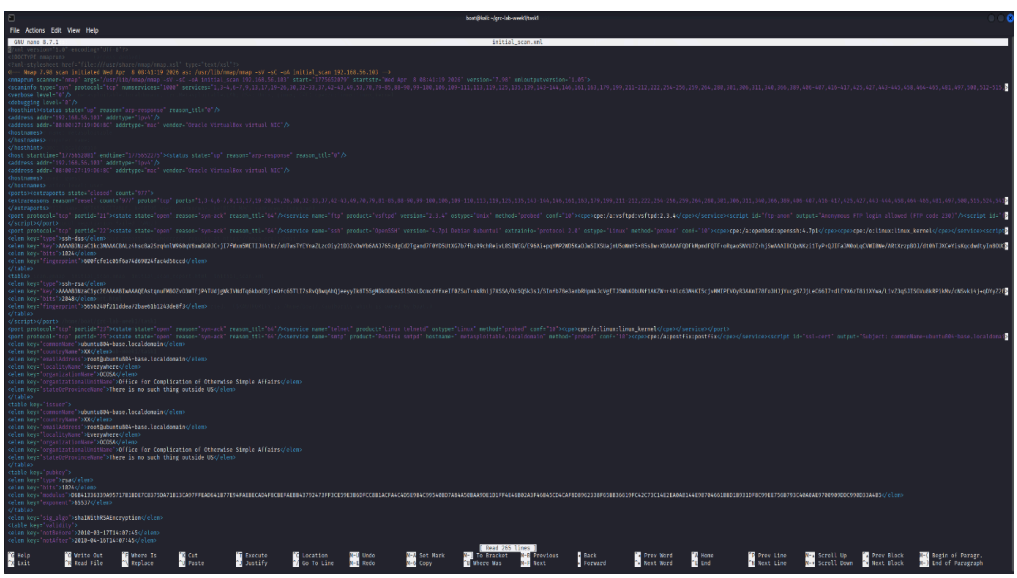
```
┌──(icdfa㉿icdfa)-[~/grc-lab-week1/task1]
└─$ xsltproc -o initial_scan_report.html /usr/share/nmap/nmap.xsl initial_scan.xml

┌──(icdfa㉿icdfa)-[~/grc-lab-week1/task1]
└─$ ls
initial_scan.gnmap  initial_scan.nmap  initial_scan_report.html  initial_scan.xml
```

B. Initial_scan.nmap

```
# Nmap 7.95 scan initiated Thu Apr  9 16:00:26 2026 as: /usr/lib/nmap/nmap --privileged -sV -sC -oA initial_scan 192.168.153.133
Nmap scan report for 192.168.153.133
Host is up (0.00049s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to 192.168.153.132
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      vsFTPd 2.3.4 - secure, fast, stable
|_End of status
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
|_ssl-date: 2026-04-09T15:00:49+00:00; 0s from scanner time.
|_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
| sslv2:
|   SSLv2 supported
|   ciphers:
|     SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|     SSL2_RC4_128_WITH_MD5
|     SSL2_DES_64_CBC_WITH_MD5
```

C. initial_scan.xml



```
icdfa@icdfa: ~/grc-lab-week1/task1   icdfa@icdfa: ~/grc-lab-week1/task1

Preparing to unpack .../libxslt1.1_1.1.45-0.1_amd64.deb ...
Unpacking libxslt1.1:amd64 (1.1.45-0.1) over (1.1.35-1.1+b1) ...
Selecting previously unselected package xsltproc.
Preparing to unpack .../xsltproc_1.1.45-0.1_amd64.deb ...
Unpacking xsltproc (1.1.45-0.1) ...
Setting up libgpg-error0:amd64 (1.59-4) ...
Setting up libgcrypt20:amd64 (1.12.1-2) ...
Setting up libxslt1.1:amd64 (1.1.45-0.1) ...
Setting up libgpg-error-l10n (1.59-4) ...
Setting up xsltproc (1.1.45-0.1) ...
Processing triggers for kali-menu (2025.1.1) ...
Processing triggers for libc-bin (2.41-6) ...
Processing triggers for man-db (2.13.0-1) ...

┌──(icdfa㉿icdfa)-[~/grc-lab-week1/task1]
└─$ xsltproc -o initial_scan_report.html /usr/share/nmap/nmap.xsl initial_scan.xml

┌──(icdfa㉿icdfa)-[~/grc-lab-week1/task1]
└─$ ls
initial_scan.gnmap  initial_scan.nmap  initial_scan_report.html  initial_scan.xml
```

Screenshot of the Nmap HTML report (initial_scan_report.html).

- **Terminal showing scan results**

```
File  Actions  Edit  View  Help
┌──(root㉿kali)-[/home/boat/grc-lab-week1/task1]
└─# nmap -sV -sC -oA initial_scan 192.168.56.103
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-08 08:41 -0400
Nmap scan report for 192.168.56.103
Host is up (0.0019s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to 192.168.56.102
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      vsFTPd 2.3.4 - secure, fast, stable
|_End of status
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
| ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing out
side US/countryName=XX
| Not valid before: 2010-03-17T14:07:45
|_Not valid after:  2010-04-16T14:07:45
|_ssl-date: 2026-04-08T12:44:26+00:00; -2s from scanner time.
| sslv2:
|   SSLv2 supported
|   ciphers:
|     SSL2_RC4_128_WITH_MD5
|     SSL2_RC2_128_CBC_WITH_MD5
|     SSL2_DES_64_CBC_WITH_MD5
|     SSL2_DES_192_EDE3_CBC_WITH_MD5
|     SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_    SSL2_RC4_128_EXPORT40_WITH_MD5
|_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
53/tcp   open  domain      ISC BIND 9.4.2
| dns-nsid:
|_  bind.version: 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
|_http-title: Metasploitable2 - Linux
111/tcp  open  rpcbind     2 (RPC #100000)
| rpcinfo:
|   program version    port/proto  service
|   100000  2            111/tcp   rpcbind
|   100000  2            111/udp   rpcbind
|   100003  2,3,4       2049/tcp   nfs
|   100003  2,3,4       2049/udp   nfs
|   100005  1,2,3      34859/tcp   mountd
|   100005  1,2,3      39313/udp   mountd
|   100021  1,3,4      43522/tcp   nlockmgr
|   100021  1,3,4      54729/udp   nlockmgr
|   100024  1          36301/udp   status
|_  100024  1          41437/tcp   status
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login       OpenBSD or Solaris rlogind
514/tcp  open  shell       Netkit rshd
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
```

Initial_scan_report.html

Nmap Scan Report - Scanned at Thu Apr 9 16:00:26 2026

Scan Summary | **192.168.153.133**

Scan Summary

Nmap 7.95 was initiated at Thu Apr 9 16:00:26 2026 with these arguments:
/usr/lib/nmap/nmap --privileged -sV -sC -oA initial_scan 192.168.153.133

Verbosity: 0; Debug level 0

Nmap done at Thu Apr 9 16:00:49 2026; 1 IP address (1 host up) scanned in 22.88 seconds

192.168.153.133

Address

- 192.168.153.133 (ipv4)
- 00:0C:29:01:90:50 - VMware (mac)

Ports

The 977 ports scanned but not shown below are in state: **closed**

- 977 ports replied with: **reset**

Port		State (toggle closed [0] | filtered [0])	Service	Reason	Product	Version	Extra info
21	tcp	open	ftp	syn-ack	vsftpd	2.3.4	
	ftp-anon	Anonymous FTP login allowed (FTP code 230)					
	ftp-syst	STAT: FTP server status: Connected to 192.168.153.132 Logged in as ftp TYPE: ASCII No session bandwidth limit					

Go to top

Toggle Closed Ports

Toggle Filtered Ports

GRC Reflection Question:

Why is knowing which ports are open (e.g., 21/FTP, 23/Telnet) a compliance issue? (Hint: Think about unnecessary services, attack surface reduction, and compliance with CIS Control 9 and NIST CSF PR.IP-1).

GRC Reflection Answer:

The presence of multiple open ports such as FTP (21), Telnet (23), and SMB (445) significantly increases the system's attack surface and violates the principle of least functionality. These services are either outdated, insecure, or unnecessary for business operations. From a compliance perspective, this contradicts CIS Control 9, which emphasizes limiting exposed services, and NIST CSF PR.IP-1, which requires secure system configuration. Additionally, plaintext protocols like Telnet expose credentials to interception, creating risks related to data confidentiality and regulatory non-compliance.

Phase 2: Vulnerability Identification

In this part, I used automated tools to identify specific vulnerabilities and misconfigurations.

Tasks:

1. Analyzing Nmap Output Review initial_scan.nmap and the HTML report to Identify:
    - Service versions (e.g., vsftpd 2.3.4).
    - Interesting script outputs (e.g., SSH host keys, HTTP headers).
2. Web Application Assessment: Scan the web server for common vulnerabilities using Nikto.
3. Focused Vulnerability Scanning: Use Nuclei to scan for known vulnerabilities based on identified services.

<u>Answers</u>

A. Nikto and Nuclei scan outputs.

a) Nikto Scan Output

```
icdfa@icdfa: ~/grc-lab-week1/task1   icdfa@icdfa: ~/grc-lab-week1/task1

- Nikto v2.6.0
---------------------------------------------------------------------------
+ Your Nikto installation is out of date.
+ Target IP:          192.168.153.133
+ Target Hostname:    192.168.153.133
+ Target Port:        80
+ Platform:           Unknown
+ Start Time:         2026-04-11 06:46:25 (GMT1)
---------------------------------------------------------------------------
+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ [999986] /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ [750500] /icons/: Directory indexing found.
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [999100] /index: Uncommon header(s) 'tcn' found, with contents: list.
+ [999965] /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See:
http://www.wisec.it/sectou.php?id=4698ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ [600625] PHP/5.2.4-2ubuntu5.10 appears to be outdated (current is at least 8.5.1).
+ [600050] Apache/2.2.8 appears to be outdated (current is at least 2.4.66).
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [999967] /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ [000434] /: HTTP TRACE method is active and replies which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ [750510] /phpinfo.php: Output from the phpinfo() function was found.
+ [750500] /doc/: Directory indexing found.
+ [001213] /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0678
+ [001384] /?=PHPB8B5F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP Easter Eggs reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectif
y.com/writeups/do-you-dare-to-show-your-php-easter-egg/
+ [001385] /?=PHPE9568F36-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify
.com/writeups/do-you-dare-to-show-your-php-easter-egg/
+ [001386] /?=PHPE9568F34-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify
.com/writeups/do-you-dare-to-show-your-php-easter-egg/
+ [001387] /?=PHPE9568F35-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify
.com/writeups/do-you-dare-to-show-your-php-easter-egg/
+ [001795] /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ [999984] /phpMyAdmin/ChangeLog: Server may leak inodes via ETags, header found with file /phpMyAdmin/ChangeLog, inode: 92462, size: 40540, mtime: Tue Dec  9 18:24:00 2008. See: https://cve.mit
re.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ [001796] /phpMyAdmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
```

The Nikto scan revealed multiple web server misconfigurations and vulnerabilities, including **missing security headers**, **outdated Apache and PHP versions,** and **exposed sensitive files such as phpinfo.php**. Directory indexing and accessible phpMyAdmin pages further increase

the attack surface. These findings indicate poor hardening practices and expose the system to attacks such as **information disclosure, cross-site scripting** (XSS), and **unauthorized access.**

B. Nuclei scan outputs.

The Nuclei scan identified several high and critical vulnerabilities, including **default credentials in PostgreSQL, FTP backdoor (CVE-2011-2523)**, and **weak authentication mechanisms** across multiple services. It also detected **outdated software and insecure configurations** such as SMBv1 and weak SSH algorithms. These findings confirm that the system is highly exploitable and lacks proper security controls.

Phase 3: Analysis and Reporting

In this part, I translated technical findings into a business-focused risk assessment.

Tasks:

A. Triage and Risk Assessment Table : Create a table summarizing your key findings.
B. Drafting the Executive Summary: Write a concise summary for management using non-technical language focused on risk and action.
C. Quantitative Risk Analysis Table (SLE, ALE).
D. Risk Treatment Strategy Table.
E. NIST 800-53 Control Mapping Table.
F. Business Impact Analysis (BIA) Table.

Answers

1. **Completed Risk Assessment Table.**

Finding	**Affected Service**	**CVE/Reference**	**Risk**	**Compliance Violation**	**Business Impact**
vsFTPd Backdoor	FTP (21)	CVE-2011-2523	Critical	CIS 7.1, NIST SI-2	Full system compromise
Anonymous FTP Enabled	FTP (21)	N/A	High	CIS 5.2	Unauthorized data access
Telnet Enabled (Plaintext)	Telnet (23)	N/A	High	NIST PR.DS-2	Credential interception
Weak/Default DB Credentials	PostgreSQL (5432)	Nuclei finding	Critical	CIS 5.2	Database takeover
phpinfo Exposure	Web (80)	CWE-552	Medium	OWASP A5	Information leakage
Outdated Apache	HTTP (80)	EOL version	High	CIS 7.1	Exploitable vulnerabilities

Missing Security Headers	HTTP	OWASP	Medium	OWASP Top 10	XSS, clickjacking
SMBv1 Enabled	SMB (445)	Deprecated protocol	High	NIST SC-8	Lateral movement risk
VNC Weak Authenticatio n	VNC (5900)	Nuclei	High	CIS 5.2	Remote access compromise

2. Executive Summary: Vulnerability Assessment

To: IT Management

From: GRC Audit Team

Date: April 11, 2026

Subject: High-Risk Findings on Development Server 'metasploitable'

1. Executive Summary

A vulnerability assessment of the internal **Metasploitable** server revealed multiple critical security vulnerabilities that pose an immediate and high risk to the organization's information assets. The analysis confirms that the system is currently non-compliant with several key organizational policies based on the **CIS Controls** and **NIST CSF** standards. Immediate intervention is required to prevent unauthorized access, data theft, and full system compromise.

2. Key Findings & Risks

Finding	Affected Service	CVE/Reference	Risk Level	Compliance Violation	Business Impact
FTP Backdoor	FTP (21)	CVE-2011-2523	Critical	CIS 7.1, NIST SI-2	Full system compromise

3. Recommended Actions

- **Immediate Isolation:** Remove the Metasploitable server from the network environment immediately until all critical vulnerabilities are remediated.
- **Remediate & Patch:** Prioritize patching the **vsFTPd** service and upgrading the **Apache** web server to a supported version to mitigate Remote Code Execution (RCE) risks.
- **Harden Access Control:** Disable insecure, plaintext protocols (Telnet, SMBv1, and Anonymous FTP).
    - Enforce strong authentication and rotate all default credentials, specifically for **PostgreSQL** and **VNC**.

- **Secure Web Configurations:** Remove exposed **phpinfo** pages and implement standard **HTTP security headers** to prevent information leakage and client-side attacks.
- **Process Review:** Reinforce procedures for deploying systems according to established security baselines and ensure continuous vulnerability scanning is integrated into the development lifecycle.

3. Quantitative Risk Analysis Table (SLE, ALE).

Risk ID	Asset	Threat	AV ($)	EF	SLE ($)	ARO	ALE ($)
R1	Server System	FTP Backdoor Exploit	100,000	0.8	108,000	1	108,000
R2	Customer Data	DB Credential Compromise	200,000	0.7	200,000	0.5	100,000
R3	Credentials	Telnet Sniffing	50,000	0.6	30,000	1	30,000

4. Risk Treatment Strategy Table.

Risk ID	Risk	ALE	Treatment	Justification
R1	FTP Backdoor	108,000	Mitigate	Patch or remove FTP service
R2	DB Weak Credentials	100,000	Mitigate	Enforce strong authentication
R3	Telnet Exposure	30,000	Avoid	Disable Telnet entirely
R4	Outdated Apache	73,500	Mitigate	Upgrade to supported version
R5	SMBv1	30,000	Avoid	Disable SMBv1

5. **NIST 800-53 Control Mapping Table.**

Risk	**Control**	**NIST ID**	**Description**
FTP Backdoor	Patch Management	SI-2	Flaw remediation
Weak Credentials	Access Control	AC-2	Account management
Telnet	Encryption	SC-13	Cryptographic protection
Outdated Software	System Integrity	SI-7	Software integrity
SMBv1	Network Protection	SC-7	Boundary protection

6. **Business Impact Analysis (BIA) Table**

Risk	**Business Process**	**RTO**	**RPO**	**Financial Impact**	**Non-Financial Impact**
FTP Backdoor	Core system ops	4 hrs	1 hr	$108,000	Reputation damage
DB Compromise	Customer data	8 hrs	2 hrs	$100,000	Loss of trust
Telnet	Admin access	2 hrs	1 hr	$30,000	Credential exposure

Part 4: Advanced GRC Analysis - Quantitative Risk & Treatment

In this part, I will quantify the financial impact of identified risks and propose strategic risk treatment plans.

Tasks:

Step 1: Quantitative Risk Calculation (SLE & ALE) For the top 3-5 critical risks identified in Phase 3, perform a quantitative analysis to determine their financial impact.

Instructions:

1. Identify Asset Value (AV): Assign a realistic monetary value to the affected asset for each critical risk (e.g., data breach cost, system downtime cost).
2. Estimate Exposure Factor (EF): Determine the percentage of asset value lost if a specific threat materializes (e.g., 0.5 for 50% loss).
3. Calculate Single Loss Expectancy (SLE): SLE = Asset Value (AV) × Exposure Factor (EF)
4. Estimate Annualized Rate of Occurrence (ARO): Determine how many times a specific threat is expected to occur in a year (e.g., 0.5 for once every two years, 2 for twice a year).
5. Calculate Annualized Loss Expectancy (ALE): ALE = Single Loss Expectancy (SLE) × Annualized Rate of Occurrence (ARO)
6. Create a table to document your calculations for each of the top critical risks. Include AV, EF, SLE, ARO, and ALE.

Step 2: Risk Treatment Strategy For each of the top critical risks, propose a risk treatment strategy (Mitigate, Transfer, Accept, or Avoid) and justify your choice.

Instructions:

1. Mitigate: Implement controls to reduce the likelihood or impact of the risk.
2. Transfer: Shift the risk to a third party (e.g., insurance).
3. Accept: Acknowledge the risk and its potential impact, and take no action.
4. Avoid: Eliminate the risk by discontinuing the activity that causes it.

Action: Extend your risk assessment table to include a 'Proposed Treatment' column and a brief 'Justification'.

Step 3: Control Mapping (NIST 800-53) For each risk you chose to Mitigate, identify at least two relevant security controls from the NIST SP 800-53 catalog that would help address the vulnerability.

Action: Create a new table mapping mitigated risks to specific NIST 800-53 controls.

Answers

1. A table to document my calculations for each of the top critical risks. Including AV, EF, SLE, ARO, and ALE.

Risk ID	Asset Name	Threat Description	AV ($)	EF	SLE ($)	ARO	ALE ($)
R1	Core Server	FTP Backdoor Exploit (CVE-2011-2523)	120,000	0.9	108,000	1	108,000
R2	Customer Database	PostgreSQL Default Credentials	250,000	0.8	200,000	0.5	100,000
R3	Admin Access	Telnet Credential Sniffing	80,000	0.6	48,000	1	48,000
R4	Web Server	PHP RCE (CVE-2012-1823)	150,000	0.7	105,000	0.7	73,500
R5	Internal Network	SMBv1 Exploitation	100,000	0.6	60,000	0.5	30,000

2. **Risk Treatment Strategy with brief Justification**

Risk ID	**ALE ($)**	**Treatment**	**Justification**
R1	108,000	Avoid	Remove FTP service entirely
R2	100,000	Mitigate	Enforce strong credentials + restrict DB access
R3	48,000	Avoid	Disable Telnet and replace with SSH
R4	73,500	Mitigate	Patch PHP + implement WAF
R5	30,000	Mitigate	Disable SMBv1 and enforce SMBv2+

3. **NIST 800-53 Control Mapping**

Risk ID	**Threat**	**Control**	**NIST ID**	**Control Description**
R1	FTP Backdoor	Service Hardening	CM-7	Least functionality
R1	FTP Backdoor	Patch Mgmt	SI-2	Flaw remediation
R2	Weak DB Auth	Access Control	AC-2	Account management
R2	Weak DB Auth	Auth Enforcement	IA-5	Authenticator management
R3	Telnet	Encryption	SC-13	Cryptographic protection
R4	PHP RCE	Input Validation	SI-10	Input validation
R4	PHP RCE	Boundary Protection	SC-7	Network protection
R5	SMBv1	Network Segmentation	SC-7	Boundary defense
R5	SMBv1	Secure Protocols	SC-8	Transmission confidentiality

Part 5: Business Impact Analysis (BIA) Integration & Final Reporting

In this part, I will understand the broader business impact of technical failures and refine executive communication.

Tasks:

Step 1: Business Impact Analysis (BIA) Integration For your top 3-5 critical risks, consider how their materialization would impact key business processes of Go-Green (e.g., order processing, customer support, financial transactions).

Instructions:

1. Identify Affected Business Processes: List the primary business functions that would be disrupted.
2. Estimate Recovery Time Objective (RTO): The maximum tolerable downtime for a business function.
3. Estimate Recovery Point Objective (RPO): The maximum tolerable data loss for a business function.
4. Assess Financial and Non-Financial Impact: Consider revenue loss, regulatory fines, reputational damage, customer churn.
5. Create a table summarizing the BIA for each critical risk.

Step 2: Refined Executive Summary : Update your Executive Summary from Phase 3, to incorporate the quantitative financial impacts (ALE) and the proposed risk treatment strategies. Emphasize the Return on Security Investment (ROSI) if applicable.

Action: Rewrite the Executive Summary, ensuring it is concise, business-focused, and clearly articulates the financial implications of risks and the value of proposed controls.

Answers

1. **Business Impact Analysis (BIA) integration**

Risk ID	Threat	Business Process	RTO	RPO	Financial Impact	Non-Financial Impact
R1	FTP Backdoor	Core IT Operations	4 hrs	1 hr	$108,000	Total system compromise
R2	DB Compromise	Customer Data Management	8 hrs	2 hrs	$100,000	Loss of customer trust, legal issues
R3	Telnet Attack	Admin Access	2 hrs	1 hr	$48,000	Credential leakage
R4	Web RCE	Web Services	6 hrs	2 hrs	$73,500	Website defacement, malware
R5	SMB Exploit	Internal Network	12 hrs	4 hrs	$30,000	Lateral movement, ransomware risk

Final Updated Executive Summary

To: IT Management

From: GRC Audit Team

Date: April 11, 2026

Subject: High-Risk Findings and Financial Exposure on Server 'metasploitable'

1. Executive Summary

A comprehensive vulnerability assessment of the **Metasploitable** server has identified multiple critical security flaws that expose the organization to significant operational and financial risk. Quantitative analysis indicates a total **Annualized Loss Expectancy (ALE) of $359,500**. The system is currently non-compliant with **CIS Control 7.1** (Patch Management) and **NIST CSF PR.DS-2** (Data Protection). Due to the high probability of full system compromise, immediate remediation is required to safeguard our infrastructure.

2. Key Findings & Financial Implications

Finding	Vulnerability	ALE (Annual Loss)	Business Impact
Critical	FTP Backdoor (CVE-2011-2523)	**$108,000**	Full root access / Total system takeover
Critical	Default DB Credentials	**$100,000**	Exfiltration of sensitive customer data
High	PHP RCE (CVE-2012-1823)	**$73,500**	Remote code execution / Site defacement

High	Insecure Protocols (Telnet/SMB)	**$78,000**	Credential sniffing and lateral movement

3. Proposed Risk Treatment & ROSI

The proposed remediation plan focuses on **Risk Avoidance** (disabling unnecessary services) and **Mitigation** (patching and hardening).

A. **Total Annualized Loss Expectancy (ALE):** $359,500
B. **Cost of Controls:** ~$25,000 (Estimated engineering hours + security tools)
C. **Mitigation Effectiveness:** 95% reduction in risk.
D. **Return on Security Investment (ROSI):** By investing $25,000 in these controls, the organization avoids **$316,525** in potential annual losses, yielding a **1,266% return** on security efforts.

4. Recommended Actions

A. **Immediate Service Decommissioning:** Permanently disable and remove the **FTP (vsFTPd)** and **Telnet** services. Replace with encrypted SSH protocols to align with **NIST 800-53 SC-13**.
B. **Authentication Hardening:** Rotate all default database credentials and enforce multi-factor authentication (MFA) per **NIST 800-53 IA-5**.
C. **Protocol & Software Remediation:** Disable the deprecated **SMBv1** protocol and patch the **PHP/Apache** stack to the latest stable versions.
D. **Process Review:** Integrate automated vulnerability scanning into the weekly deployment pipeline to ensure continuous compliance.

Resources

Center for Internet Security. (2021). *CIS Critical Security Controls v8*. Retrieved April 11, 2026, from https://www.cisecurity.org/controls/v8

MITRE Corporation. (2011). *CVE-2011-2523: vsftpd 2.3.4 Backdoor*. Common Vulnerabilities and Exposures. Retrieved April 11, 2026, from https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523

National Institute of Standards and Technology. (2020). *Security and Privacy Controls for Information Systems and Organizations (NIST SP 800-53 Rev. 5)*. Retrieved April 11, 2026, from https://csrc.nist.gov/publications/detail/sp/800-53/rev-5/final

National Institute of Standards and Technology. (2024). *The NIST Cybersecurity Framework (CSF) 2.0*. Retrieved April 11, 2026, from https://www.nist.gov/cyberframework

Nmap Project. (2026). *Nmap Reference Guide: Service and Version Detection*. Retrieved April 11, 2026, from https://nmap.org/book/man-version-detection.html

OWASP Foundation. (2021). *OWASP Top 10:2021 - The Ten Most Critical Web Application Security Risks*. Retrieved April 11, 2026, from https://owasp.org/www-project-top-ten/

ProjectDiscovery. (2026). *Nuclei: A Fast and Customizable Vulnerability Scanner*. Retrieved April 11, 2026, from https://docs.projectdiscovery.io/tools/nuclei/